

NPC Advisory No. 2025 – 02

DATE : 27 August 2025

SUBJECT : GUIDELINES ON PRIVACY ENGINEERING IN SYSTEMS LIFE CYCLE PROCESSES

WHEREAS, Section 7 (g) of the Data Privacy Act of 2012 (DPA) provides that the National Privacy Commission (NPC) is empowered to publish, on a regular basis, a guide to all laws relating to data protection;

WHEREAS, pursuant to Chapter V, Section 20 (a) of the DPA, the personal information controller must implement reasonable and appropriate organizational, physical, and technical measures intended for the protection of personal information against any accidental or unlawful destruction, alteration, and disclosure, as well as against any other unlawful processing;

WHEREAS, Rule VI, Section 25 of the Implementing Rules and Regulations (IRR) of the DPA provides that Personal Information Controllers (PICs) and Personal Information Processors (PIPs) shall implement reasonable and appropriate organizational, physical, and technical security measures for the protection of personal data;

WHEREAS, Rule II, Section 8 of the NPC Circular 2023-06 or the Security of Personal Data in the Government and the Private Sector provides that a PIC or a PIP should incorporate data privacy requirements throughout the development and implementation of data processing systems;

WHEREAS, the NPC recognizes the need to provide clear and practical guidance to PICs and PIPs on how to develop and implement data processing systems that respect and uphold the data privacy rights of data subjects throughout the systems life cycle processes;

WHEREAS, integrating privacy engineering principles and practices into the planning, development, deployment, and maintenance of data processing systems can help PICs and PIPs meet their obligations under the DPA and its IRR;

WHEREAS, the NPC has received numerous inquiries from PICs seeking guidance on developing and implementing privacy-respecting data processing systems;

WHEREFORE, in view of the foregoing, the NPC hereby issues this Advisory to provide guidelines on privacy engineering in systems life cycle processes.

SECTION 1. *Purpose.* - This Advisory aims to provide guidelines to PICs and PIPs on integrating data privacy into the systems life cycle processes. It includes both high-level strategies and specific guidelines on the following:

- A. Providing clear and practical guide to PICs and PIPs for incorporating privacy engineering principles and practices into the planning, development, testing, deployment, and maintenance of data processing systems;
- B. Establishing the basis and rationale for these guidelines under the provisions of the DPA, its IRR, and relevant NPC issuances;
- C. Promoting a privacy-by-design and privacy-by-default approach in the development and implementation of data processing systems to safeguard data subjects' rights; and
- D. Assisting PICs and PIPs in meeting their obligations under the DPA and its IRR by implementing reasonable and appropriate security measures throughout the systems life cycle processes.

SECTION 2. *Scope.* - This Advisory shall apply to all PICs and PIPs engaged in the processing of personal data through data processing systems. The Advisory discusses the integration of privacy engineering principles and practices in the following stages of the systems life cycle:

- A. Planning and requirements gathering;
- B. Designing and development;
- C. Testing and evaluation;
- D. Deployment and integration; and
- E. Operation and maintenance.

SECTION 3. *Definition of Terms.* - For the purpose of this Advisory, the following terms are adopted from the DPA, its IRR, and other relevant issuances of the NPC, and defined as follows:

- A. "*Access Controls*" refers to security measures that ensure only properly authorized users can access the minimum necessary personal data;
- B. "*Anonymization*" refers to a process by which personal information, including sensitive personal information, is irreversibly altered in such a way that a data subject can no longer be identified directly or indirectly, either by the PIC alone or in collaboration with any other party;
- C. "*Privacy Architecture*" refers to the design and implementation of processes, controls, and systems to ensure privacy principles are upheld in the technological infrastructure of organizations;¹
- D. "*Privacy Engineering*" refers to the integration of privacy concerns into engineering practices for systems and software engineering life cycle processes;
- E. "*Privacy-by-Design*" refers to a set of principles in the development and implementation of projects, programs, and processes that integrates safeguards that are necessary to protect and promote privacy unto the design or structure of a processing activity or a data processing system;

¹ National Institute of Standards and Technology. *Privacy Architecture - Glossary* | CSRC. , available at https://csrc.nist.gov/glossary/term/privacy_architecture#:~:text=Definitions%3A,enterprise's%20mission%20and%20strategic%20plans.

- F. *“Privacy-by-Default”* refers to the principle according to which the PIC or PIP ensures that personal data is automatically protected by default, without the intervention of the user or the data subject;
- G. *“Privacy Notice”* refers to a unilateral statement that contains essential information on a specific processing activity of a PIC that involves the data subject;
- H. *“Pseudonymization”* refers to the process applied to personal information, including sensitive personal information, which replaces identifying information with an alias;
- I. *“Software Development”* refers to the process of creating, designing, deploying, testing, and maintaining a software application;
- J. *“Source Code”* or *“Code”* refers to a set of human-readable instructions that a programmer writes to make instructions for a computer program, software, or application;
- K. *“Systems life cycle”* refers to the period that begins when a system is conceived and ends when the system is no longer available for use;²
- L. *“Threat Modelling”* refers to a systematic exploration technique that exposes any circumstance or event that has the potential to cause harm to a system in the form of destruction, disclosure, and modification of data or denial of service;
- M. *“Third Party”* refers to an entity engaged by a PIC or PIP to develop systems, software, or applications.

SECTION 4. Guidelines. – PICs and PIPs shall apply data privacy measures, including privacy-by-design and privacy-by-default principles throughout the entire system lifecycle of data processing systems, as outlined in Section 2. These measures shall apply regardless of the system’s phase or status, whether newly developed, currently operational, or undergoing updates. The following guidelines shall be observed throughout all phases of the system lifecycle:

- A. Planning and Requirements Gathering
 - 1. PICs and PIPs shall determine the lawful basis for processing personal data,³ and ensure that the purpose, scope, and manner of processing are compatible with the declared and specified purpose;
 - 2. PICs and PIPs shall apply the general data privacy principles of transparency, legitimate purpose, and proportionality in collecting personal data.⁴ PICs and PIPs should only collect data that is adequate, relevant, suitable, necessary, and not excessive in relation to a declared and specified purpose, and retain it only for a specified period to fulfill that purpose or as required by law;
 - 3. PICs and PIPs shall conduct a Privacy Impact Assessment (PIA), in accordance with the NPC’s issuance on PIA⁵ to identify and evaluate the potential risks⁶

² ISO/IEC/IEEE 21840:2019(En), Systems and Software Engineering – Guidelines for the Utilization of ISO/IEC/IEEE 15288 in the Context of System of Systems (SoS), available at <https://www.iso.org/obp/ui#iso:std:iso-iec-ieee:21840:ed-1:v1:en:term:3.1.11>.

³ Section 12 of the Republic Act 10173 - Data Privacy Act of 2012.

⁴ Section 11 of the Republic Act 10173 - Data Privacy Act of 2012.

⁵ NPC Advisory No.2017-03: Guidelines on Privacy Impact Assessments, available at https://privacy.gov.ph/wp-content/uploads/2022/01/NPC_AdvisoryNo.2017-03.pdf.

⁶ Section 20(c) of the Republic Act 10173 - Data Privacy Act of 2012, National Privacy Commission, available at <https://privacy.gov.ph/data-privacy-act/>.

and effects that the proposed data processing system may have on the data subjects, and to identify ways in which any adverse effects can be mitigated.

B. Designing and Development

1. Minimize the processing of personal data by implementing architectures, practices, and techniques that reduce the use, collection, and retention of personal data to what is necessary in relation to the specified purpose;
2. Implement appropriate security measures to maintain the confidentiality, integrity, and availability of personal data.⁷ These may include, but are not limited to:
 - a. Anonymization and pseudonymization to protect personal data;
 - b. Privacy-enhancing technologies (PETs)⁸ that either minimize or eliminate the processing of personal information;
 - c. Encryption for data at rest and in transit;
 - d. Access controls to ensure that only authorized personnel can access personal data; and
 - e. Develop and implement a disaster recovery plan to ensure the immediate restoration of data access in the event of system failures.⁹
3. Implement measures within the system for data subjects to exercise their rights under the DPA,¹⁰ such as but not limited to: data access and download tools to request access to their personal data within the system; correction and rectification interfaces that allow users to rectify incorrect personal data; deletion or erasure options, to allow users to delete data within the system; and provide opt-in and opt-out mechanisms for specific processing of personal data;
4. Maintain traceability in the data processing system involving access or changes made to personal information;¹¹
5. Adopt secure software development practices that integrate privacy considerations throughout the systems life cycle processes, including:
 - a. Threat modelling to identify and mitigate privacy risks early in the development process;
 - b. Static and dynamic source code analysis to detect and fix security and privacy vulnerabilities; and
 - c. Fuzzing¹² to detect security and privacy issues by providing unexpected or random data as inputs.
6. Establish data retention policies that define how long personal data can be stored, e.g., use of temporal data, where collected data is regularly deleted after usage;

⁷ Section 25 of the Implementing Rules and Regulations of the Data Privacy Act of 2012, available at <https://privacy.gov.ph/implementing-rules-regulations-data-privacy-act-2012/>.

⁸ Data Protection Engineering From Theory to Practice, available at <https://www.enisa.europa.eu/sites/default/files/publications/ENISA%20Report%20-%20Data%20Protection%20Engineering.pdf>

⁹ Section 28(e) of the IRR of DPA.

¹⁰ Section 16 of the Republic Act 10173 – Data Privacy Act of 2012.

¹¹ Section 16 and 19 of the NPC Circular 2023-06: Security of Personal Data in the Government and the Private Sector, available at <https://privacy.gov.ph/wp-content/uploads/2024/03/NPC-Circular-Repeal-16-01-Signed.pdf>.

¹² Fuzz testing or fuzzing is an automated software testing method that injects invalid, malformed, or unexpected inputs into a system to reveal software defects and vulnerabilities, available at <https://www.synopsys.com/glossary/what-is-fuzz-testing.html#:~:text=Definition,as%20crashes%20or%20information%20leakage>.

7. Implement secure disposal procedures and practices to ensure personal data is permanently deleted when it is no longer needed.

C. Testing and Evaluation

1. Perform data privacy and security testing¹³ to verify the effectiveness of the security and privacy controls and settings of the data processing system before deployment;
2. Test the usability of the privacy interfaces, such as the accessibility of privacy notices that are clear and understandable¹⁴ and testing the mechanism on how data subjects can easily exercise their privacy rights through the system;
3. Conduct code reviews and vulnerability scans to identify and address any security flaws and weaknesses that can lead to unauthorized access and data breaches;¹⁵
4. Conduct a privacy architecture¹⁶ review to ensure that technologies, architectures, and protocols used in the data processing system support data privacy objectives and requirements of the DPA, IRR, and issuances of the NPC.

D. Deployment and Integration

1. Provide data subjects with clear and concise privacy notices regarding the collection and processing of their personal data, including their rights and how to exercise them.¹⁷ For example, users should be informed about the data that an application or a data processing system will be processing. Avoid deceptive design patterns to ensure transparency and trust.¹⁸ This approach not only delivers clear privacy notices but also enhances the overall trustworthiness of data processing systems;
2. Obtain the proper consent of data subjects,¹⁹ when consent is the lawful basis for processing, before collecting and processing their personal data;
3. Ensure that the default settings of the data processing system provide the maximum privacy protection without manual intervention from data subjects. Some examples include, but are not limited to the following: the security settings of a system should be enabled by default; online forms only require essential information by default and leaving optional fields unrequired; opt-in consent mechanism by default with unchecked consent boxes; default user profiles should be private rather than public; location tracking should be disabled by default; and payment details should not be saved by default.

E. Operation and Maintenance

¹³ Section 28(f) of the Implementing Rules and Regulations of the Data Privacy Act of 2012.

¹⁴ NPC Advisory 2021-01: Data Subject Rights, available at <https://privacy.gov.ph/wp-content/uploads/2021/02/NPC-Advisory-2021-01-FINAL.pdf>.

¹⁵ Section 28(b) of the Implementing Rules and Regulations of the Data Privacy Act of 2012.

¹⁶ ISO/IEC 29101:2018(En), Information Technology – Security Techniques – Privacy Architecture Framework, available at <https://www.iso.org/obp/ui/en/#iso:std:iso-iec:29101:ed-2:v1:en>.

¹⁷ Section 6 of the NPC Advisory 2021-01: Data Subject Rights.

¹⁸ NPC Advisory No. 2023-01: Guidelines on Deceptive Design Patterns,” available at https://privacy.gov.ph/wp-content/uploads/2023/11/NPC-Advisory-No.-2023-01-Guidelines-on-Deceptive-Design-Patterns_7Nov23.pdf.

¹⁹ NPC Circular No. 2023-04: Guidelines on Consent

1. Regularly monitor the data processing system for any security incidents and data breaches, and implement policies and procedures for incident response and breach notification;²⁰
2. Conduct periodic audits and PIAs at least once a year to assess the continued effectiveness of the privacy controls and address any gaps or new risks;²¹ A new PIA must be conducted in case of the following: (1) a major update or enhancement to an existing system is made; (2) a new vendor or third party processor is engaged; and (3) changes in the nature, scope, extent, or purpose of processing;
3. Promptly address any vulnerabilities and update the privacy controls of the data processing system based on the latest risks and security standards;
4. Uphold the requests of data subjects in exercising their rights (e.g., right to access, rectify, object, etc.) in accordance with the DPA, its IRR and the NPC's issuance on Data Subjects' Rights;²²
5. Train personnel on the secure processing in the application or data processing system,²³ as well as managing security incidents as stipulated in the NPC's issuance on Security Incident Management.

SECTION 5. *Interpretation.* – Any doubt in the interpretation of any provision of this Advisory shall be liberally interpreted in a manner mindful of the rights and interests of the data subject.

Approved:

SGD.
JOHN HENRY D. NAGA
Privacy Commissioner

SGD.
NERISSA N. DE JESUS
Deputy Privacy Commissioner

SGD.
JOSE AMELITO S. BELARMINO II
Deputy Privacy Commissioner

²⁰ Section 28(d-e) of the Implementing Rules and Regulations of the Data Privacy Act of 2012.

²¹ Section 28(f) of the Implementing Rules and Regulations of the Data Privacy Act of 2012.

²² NPC Advisory 2021-01: Data Subject Rights.

²³ Section 26(d) of the Implementing Rules and Regulations of the Data Privacy Act of 2012.